

RANSOMWARE & EXTORTION INCIDENT RESPONSE PLAY-BOOK

Document Control ID: DFIR-PB-001 **Target Standard:** NIST SP 800-61 Rev. 3 / ISO/IEC 27037 **Case Tracking Number:** [INSERT_CASE_ID] **Lead Investigator:** [INSERT_EXAMINER_NAME] | **Lab/Agency:** [INSERT_ORGANIZATION] **Date of Incident:** [INSERT_INCIDENT_DATE] | **Classification:** HIGHLY CONFIDENTIAL / PRIVILEGED

1. INCIDENT SEVERITY & ESCALATION MATRIX

Severity Level	Trigger Criteria	Initial Response SLA	Authorized Incident Commander
Level 1 (Critical)	Active domain-wide encryption, DC compromised, backup destruction.	Immediate (< 15 min)	CISO / Legal Lead / Lead Examiner
Level 2 (High)	Multi-host encryption/exfiltration confirmed, EDR disabled on subnet.	< 1 Hour	Incident Response Lead
Level 3 (Medium)	Single isolated workstation encrypted, lateral movement blocked.	< 4 Hours	Senior DFIR Examiner
Level 4 (Low)	Ransomware execution attempted but blocked by endpoint telemetry.	< 24 Hours	SOC Tier 2 Analyst

2. PHASE 1: IMMEDIATE ISOLATION & CONTAINMENT

CRITICAL EVIDENCE PRESERVATION RULE: DO NOT reboot or power down live endpoints immediately. Volatile memory (RAM) contains active encryption keys, command-and-control (C2) sockets, and injected payload artifacts.

2.1 Network & Endpoint Isolation

Execute containment commands in order of operational priority:

1. Host-Level Network Interface Disablement:

```
# Disable all active physical and virtual network interfaces
Get-NetAdapter | Where-Object { $_.Status -eq "Up" } | Disable-NetAdapter -
Confirm:$false
```

2. Block Outbound Command & Control (C2):

```
# Create an emergency outbound block rule
New-NetFirewallRule -DisplayName "DFIR-Emergency-C2-Block" -Direction Outbound -
Action Block -Profile Any
```

3. Terminate Lateral Movement Vector (SMB/RPC):

```
# Stop Server service immediately
Stop-Service -Name LanmanServer -Force
```

3. PHASE 2: EVIDENCE PRESERVATION & ARTIFACT HUNTING

- ☐ **Live Volatile RAM Capture:** Run winpmem.exe or DumpIt.exe directly to an external triage drive (E:\).
 - ☐ **Volume Shadow Copies (VSS):** Check if shadow copies exist (vssadmin list shadows) before malware can delete them.
 - ☐ **KAPE Triage Collection:** Extract \$MFT, \$LogFile, \$UsnJrnl, Prefetch (C:\Windows\Prefetch), and Event Logs (.evtx).
 - ☐ **Ransom Note & Sample Isolation:** Secure an encrypted sample file alongside the ransom note (README.txt / .hta).
-

4. PHASE 3: ROOT CAUSE & INITIAL ACCESS ANALYSIS

Interrogate the following artifact vectors to determine patient zero and entry mechanism:

Vector	Forensic Target	Query / Investigation Method
External RDP / VPN	Security Log Event ID 4624 (Type 10 / Type 3)	Look for anomalous source IPs or credential spray patterns.
Phishing / Email	Outlook PST/OST, Recent LNK files, Downloads	Inspect execution of ISO, ZIP, LNK, or macro-enabled documents.
Public Exploits	IIS / Apache / VPN Gateway Access Logs	Search for POST requests targeting known CVE endpoints.
Privilege Escalation	Event ID 4672, 7045 (New Service), PsExec	Hunt for injected services, Cobalt Strike beacons, or Mimikatz traces.

5. PHASE 4: EXTORTION & EXFILTRATION TRIAGE

- ☐ **Cloud Storage Sync & Web Uploads:** Check browser history and cloud tool database files (SyncEngineDatabase.db, filecache.db).
- ☐ **Mega / Rclone Staging:** Inspect registry HKCU\Software\rclone and prefetch traces for RCLONE.EXE or MEGASYNC.EXE.
- ☐ **Network Egress Volume:** Request firewall NetFlow / perimeter egress logs to quantify exfiltrated megabytes.

6. PHASE 5: ERADICATION, RECOVERY & LESSONS LEARNED

1. **Active Directory Reset:** Perform a double Kerberos Ticket-Granting Service (krbtgt) password reset across domain controllers.
2. **Gold Master Rebuilds:** Never attempt to “clean” an encrypted host; re-image all impacted operating systems from trusted bare-metal gold images.
3. **Decryption Tool Verification:** Submit isolated ransomware sample binaries and notes to *NoMoreRansom.org* to verify if public decryptors exist before considering ransom negotiations.
4. **Post-Mortem Incident Timeline:** Consolidate artifact timestamps into the Master DFIR Investigation Report within 72 hours of containment.